

SHADOW AI AUDIT REPORT

What your team is doing in the dark — and what to do about it.

Acme Capital Ltd

Audit period: 2026-04-26 to 2026-05-02

REPORT ID

FL-2026-05-03-acme-capital

GENERATED

2026-05-03

HEADCOUNT AUDITED

47 of 52 employees

INDUSTRY

Financial Services (FCA-regulated)

PRIMARY JURISDICTION

United Kingdom

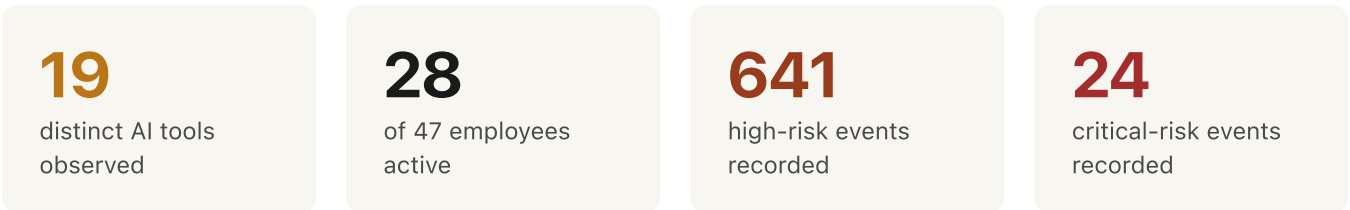
PREPARED BY

Floodlight Security

Confidential. Prepared for Acme Capital Ltd. Do not distribute outside the organisation without written permission. The contents reflect activity observed during the audit period and should be read alongside the methodology in §6.

The headline finding

Across 47 employees over 7 days, your team interacted with **19 distinct AI tools**. Of those, 6 are rated High or Critical risk by Floodlight's taxonomy — meaning they train on user inputs by default, are hosted in concerning jurisdictions, or both. The classifier observed **128 paste events** containing patterns that match sensitive content categories, including 7 pastes containing credentials and 62 containing source code.



Tool risk distribution

How the 19 observed tools split across Floodlight's risk bands.



Top three things to do this week

1 Investigate 7 credential pastes

Severity: critical

Effort: low

The classifier flagged pastes matching API key formats (OpenAI, AWS, GitHub, JWT) into ChatGPT and Cursor. Treat any matched key as compromised: rotate immediately and review the access logs for those credentials over the audit period.

2 Decide your stance on Critical-rated tools

Severity: high

Effort: medium

3 Critical-rated tools were used during the audit period: DeepSeek, Character.AI, Replika. Each presents a defensible reason to block at the network layer or via endpoint policy. See §5 for category-by-category recommendations.

3 Document AI literacy obligations under EU AI Act Article 4

Severity: medium

Effort: medium

Article 4 (AI literacy) has been in force since 2 February 2025. As a deployer of AI systems, your organisation is required to take measures to ensure a sufficient level of AI literacy among staff. This audit, plus a written acceptable-use policy and training record, satisfies the demonstrable-effort threshold. See §4 for the full mapping.

Every AI tool observed, ranked by risk

The table below lists every distinct AI tool that one or more employees interacted with during the audit period. The risk band reflects Floodlight's published taxonomy (see §6 for methodology). Where a tool offers multiple tiers (e.g. ChatGPT Free vs Enterprise), the most-conservative tier is assumed unless an admin policy indicates otherwise.

TOOL	CATEGORY	RISK	EVENTS	USERS	TRAINS ON INPUT	NOTES
DeepSeek	Llm Chat	CRITICAL	12	2	Yes	Hosted in China; subject to PRC data laws; corporate use strongly discouraged in regulated sectors
Character.AI	Llm Chat	CRITICAL	8	1	Yes	Persona chat platform; high PII risk
Replika	Risky	CRITICAL	4	1	Yes	Companion AI; intimate personal content commonly shared
ChatGPT	Llm Chat	HIGH	612	28	Yes	Free/Plus tier detected — trains on inputs unless opted out
Suno	Audio	HIGH	6	2	Yes	Music generation; free tier outputs public
Bolt.new	Code	HIGH	23	3	Yes	Generates whole apps; prompts and code may be used for improvement
GitHub Copilot	Code	MEDIUM	198	9	Configurable	Individual tier may use prompts for training
Perplexity AI	Search	MEDIUM	156	21	Configurable	Consumer tier retains queries for service improvement
Microsoft Copilot	Llm Chat	MEDIUM	87	16	Configurable	Consumer version detected — different policy from M365 Copilot

TOOL	CATEGORY	RISK	EVENTS	USERS	TRAINS ON INPUT	NOTES
Google Gemini	Llm Chat	MEDIUM	134	11	Configurable	Consumer tier may use conversations for product improvement
Midjourney	Image	MEDIUM	14	3	Yes	Default plans show outputs publicly
Otter.ai	Meeting	MEDIUM	54	6	No	Auto-joining meetings; transcripts often shared widely
Cursor	Code	MEDIUM	98	7	Configurable	Privacy Mode available but not enforced by default
Grammarly	Writing	MEDIUM	78	13	Yes	Free/Premium tier retains content for up to 36 months
v0 by Vercel	Code	MEDIUM	4	2	Configurable	Generates UI; team plans available
Claude	Llm Chat	LOW	287	14	No	Does not train on user inputs by default
Notion AI	Note	LOW	35	8	No	Bound to workspace DPA; does not train on customer data
DeepL	Translate	LOW	28	9	No	GDPR-native; Pro plan does not store text
Adobe Firefly	Image	LOW	9	3	No	Trained on licensed/public-domain content; commercial-safe

Reading note. A tool appearing on this list does not, on its own, indicate a compliance breach or a security incident. It indicates the presence of an AI tool in your environment that warrants a governance decision. The recommendations in §5 propose three policy modes (block, allow, educate) you can apply per tool.

What the local classifier flagged

Each time an employee pastes content into an AI prompt field, Floodlight's classifier scans the paste locally on the endpoint for patterns that match 9 sensitive-content categories. Only the category labels and counts leave the device — **the actual pasted content is never logged or transmitted**. The numbers below reflect the classifier's pattern matches, not human-verified leaks.

Categories observed

CATEGORY	PASTES	TOOLS WHERE OBSERVED
Source code <code>source_code</code>	62	Bolt.new, ChatGPT, Claude, Cursor, GitHub Copilot, v0 by Vercel
Email address <code>email</code>	50	ChatGPT, Claude, GitHub Copilot, Grammarly, Perplexity AI
UUID (likely a database identifier) <code>uuid</code>	12	ChatGPT, Claude, Cursor
UK phone number <code>phone_uk</code>	7	ChatGPT
IPv4 address <code>ip_address</code>	6	ChatGPT, GitHub Copilot
OpenAI API key <code>api_key_openai</code>	3	ChatGPT
IBAN (international bank account) <code>iban</code>	2	ChatGPT, Claude
Credit card number (16-digit pattern) <code>credit_card</code>	1	ChatGPT
JSON Web Token <code>jwt</code>	1	ChatGPT

High-concern events (chronological)

Pastes flagged by the classifier as containing credentials, regulated identifiers, or financial account numbers. These warrant immediate triage.

TIME (UTC)	TOOL	CATEGORIES	BYTES	USER
2026-04-26T11:04:20Z	ChatGPT	<code>api_key_openai</code>	1423	<code>user-c049</code>
2026-04-26T14:23:16Z	ChatGPT	<code>email</code> <code>credit_card</code>	2786	<code>user-2e73</code>
2026-04-29T12:45:19Z	Claude	<code>iban</code>	3451	<code>user-fbaa</code>

TIME (UTC)	TOOL	CATEGORIES	BYTES	USER
2026-04-30T19:53:36Z	ChatGPT	jwt	1672	user-b790
2026-04-30T22:33:19Z	ChatGPT	api_key_openai	490	user-8fb1
2026-05-01T05:19:17Z	ChatGPT	api_key_openai	2105	user-5cb6
2026-05-01T19:48:24Z	ChatGPT	phone_uk ip_address iban	3343	user-c049

How to read the User column. Floodlight assigns each browser install a random pseudonym (a UUID stored only on the endpoint). The pseudonym identifies a device, not a human. To map a pseudonym to an employee, your IT admin can correlate against the assigned device inventory — deliberately a manual step to limit casual exposure.

How these findings sit against the relevant regulations

For a UK-based organisation in financial services, four regulatory frameworks bear on shadow AI usage. The mapping below cites the specific obligation each finding touches.

EU AI Act — Regulation (EU) 2024/1689

OBLIGATION	APPLIES BECAUSE	EVIDENCE IN THIS AUDIT
Article 4 — AI literacy In force from 2 Feb 2025.	You are a deployer of AI systems (any third-party LLM or AI tool used by staff).	Use this audit + a written AUP + a training record to demonstrate the "sufficient level of AI literacy" measure required by the article.
Article 5 — Prohibited AI practices	None of the tools observed in this audit fall under Article 5 prohibitions.	Re-evaluate quarterly as new tools enter the environment.
Articles 9, 10, 13 — High-risk system obligations In force from 2 Aug 2026.	If any AI tool is used to make decisions in scope of Annex III (e.g. credit scoring, employment), high-risk obligations attach.	Conduct an Annex III applicability review for 6 chat/agent tools observed.

UK GDPR — Regulation (EU) 2016/679 as retained

OBLIGATION	APPLIES BECAUSE	EVIDENCE IN THIS AUDIT
Article 5(1)(f) — integrity and confidentiality	Personal data was pasted into AI tools that train on inputs by default.	59 pastes contained patterns matching personal data (email, UK phone, NI number, IBAN).
Article 32 — security of processing	Pasting personal data into a third-party processor that may train on it constitutes processing.	Review whether DPAs are in place with each tool's vendor; for tools without a DPA, restrict to non-personal-data use cases.
Article 44 — international transfers	1 tool(s) hosted in jurisdictions without an adequacy decision were used during the audit.	Transfers of personal data to these tools are unlawful absent appropriate safeguards (SCCs are unlikely to be effective for PRC-hosted services). Recommend immediate block.

FCA — SYSC 6.1.1R & Operational Resilience

OBLIGATION	APPLIES BECAUSE	EVIDENCE IN THIS AUDIT
SYSC 6.1.1R — adequate policies and procedures	You are an FCA-authorised firm.	A written Acceptable Use Policy covering AI tools, alongside this audit, evidences adequate policy.
SYSC 13 — outsourcing & third-party risk	AI tool usage is a form of third-party processing.	Each Medium-or-higher rated tool should appear on the third-party register or be blocked.

ISO/IEC 42001:2023 — AI Management System

Voluntary but increasingly expected by enterprise procurement. This audit produces evidence aligned with clauses 6.1.2 (AI risk assessment), 8.2 (operational planning), and Annex A controls A.5.2–A.5.5 (data, intended use, AI system impact assessment).

What to do, in priority order

Recommendations are ranked by impact-per-effort. The first two are intended to be completed within the week; the next four within the month; the last two are quarterly governance practices.

This week

R1 — Rotate all credentials matched in §3

2–4 HOURS

Treat each API key and JWT in the high-concern events table as compromised. Rotate, invalidate sessions, and review access logs for the affected credentials over the audit period and the preceding 30 days.

R2 — Block Critical-rated tools at the network layer

1–2 HOURS

Block DeepSeek, Character.AI, Replika via your DNS filtering or secure web gateway. These tools either train on inputs and are hosted in concerning jurisdictions, or are designed for personal/intimate use that should not occur on corporate devices.

This month

R3 — Publish a written AI Acceptable Use Policy

1–2 DAYS

Cover: which tools are sanctioned (and at which tiers), what data may never be pasted, the consequences of policy breach, and the contact for exception requests. Bind via existing employment contract or staff handbook.

R4 — Upgrade ChatGPT users to Team or Enterprise

1 WEEK

The single highest-volume tool in this audit (ChatGPT, 612 events, 28 users) is being used on the Free or Plus tier, which trains on inputs by default. Team tier (£25/user/month at the time of writing) does not train on inputs and offers admin retention controls. ROI: a single sanctioned tier replaces dozens of policy exceptions.

R5 — Roll out Floodlight in "educate" mode

2–4 HOURS

Switch the extension's default policy from passive monitoring to "educate": when a high-concern paste is detected, the user sees a brief in-page popup explaining the risk before proceeding. This converts the audit's findings from retrospective reporting into prospective prevention without blocking productivity.

R6 — Add AI tools to your third-party risk register

1 DAY

Each Medium-or-higher rated tool should be listed in your third-party register with its DPA status, data-processing scope, and risk owner. This is required by FCA SYSC 13 and aligns with ISO 27001 A.15.

Quarterly

R7 — Re-run the audit each quarter

1 DAY PER QUARTER

The AI vendor landscape changes weekly. New tools enter your environment, vendor policies change with new tiers, and certifications expire. A quarterly cadence catches drift before it becomes incident.

R8 — Conduct an EU AI Act Annex III applicability review

1–2 DAYS

Before 2 August 2026, identify any AI tool used in connection with Annex III activities (credit scoring, employment decisions, etc.). Tools used in those contexts inherit the high-risk obligations of Articles 9, 10, and 13.

How this audit was conducted

Data collection

During the audit period, the open-source Floodlight browser extension was deployed on participating employees' work browsers. The extension monitors a fixed list of 19+ AI tool domains (the full list is published in the extension's manifest). When an employee visits one of those domains, the extension records a navigation event. When an employee pastes content into a prompt-like field on one of those domains, the extension classifies the pasted content **locally in the browser** using a regex-based classifier covering 9+ categories, and emits a paste event containing only the category labels and match counts.

The privacy contract. Pasted text is never logged, transmitted, or stored. Only category labels and counts leave the endpoint. The extension is open-source and can be audited at github.com/floodlightsecurity/floodlight.

Risk scoring

Each tool in the taxonomy receives a numeric risk score (1–10) and a band (Low / Medium / High / Critical) based on four factors weighted in this order: (1) whether the tool trains on user inputs by default; (2) hosting jurisdiction and data sovereignty; (3) compliance certifications (SOC 2, ISO 27001, HIPAA-eligibility); (4) data retention defaults. The full methodology is published at github.com/floodlightsecurity/floodlight/blob/main/data/RISK_METHODOLOGY.md.

Limitations

This audit captures activity on managed browsers within the audit window. It does *not* capture: AI usage on personal/BYOD devices or mobile; AI features embedded in already-sanctioned platforms (M365 Copilot, Slack AI, Salesforce Einstein) which are inferred via their own audit logs and would require separate integration; native desktop AI applications that do not run in a browser. Closing those gaps requires DNS-level monitoring or MDM-based enforcement; both are roadmap items.

What this report is not

This is not a legal opinion on whether any specific tool's use complies with UK GDPR, the EU AI Act, or any other regulation in your specific operational context. Compliance turns on factors beyond the scope of monitoring — your DPA with the vendor, your legal basis under Article 6, the outcome of your DPIA, and so on. Treat this report as a starting point for a conversation with your DPO and legal team, not as a substitute for one.

Contact

Prepared by Floodlight Security. For questions or corrections, reply to the email this report was attached to. For methodology issues or pull requests, see the public repository.